Lab Assignment 4

Stepan Shkrobak

Dr. Michael Bartolacci

IST 894, Section 001: Capstone Experience,

22 February 2026

Table of Contents

Table of Contents.....2
General Context.....3
Technical Context.....3
Screenshots.....5
References.....7

General Context

The Common Attack Types lab focused on common web application attack types, specifically injection-based vulnerabilities. We looked at input validation and insufficient output encoding, which allow attackers to manipulate application logic or execute unintended commands. These vulnerabilities showed that untrusted user input, when incidentally imported into database queries or system calls, can compromise data and the database. Injection flaws remain consistently ranked among the most critical web application risks because they can expose sensitive data, bypass authentication controls, and potentially lead to full system compromise (OWASP Foundation, 2021).

The lab also helped show how the development lifecycle and defensive principles are important. Attackers can exploit both visible and blind vulnerabilities, including scenarios where compromise is inferred through system behavior rather than a direct output. These were real-world threat activities, where adversaries adapt techniques based on application responses. Industry research indicates that injection flaws persist largely due to inadequate validation mechanisms and insufficient testing processes (Veracode, 2023). The exercise highlighted the importance of implementing parameterized queries, strong input validation, least privilege access controls, and routine security assessments to reduce exposure at the application layer.

The Recon and footprinting course covered reconnaissance and footprinting methods as foundational phases in penetration testing. The course introduced structured information gathering using domain registration data, DNS records, regional internet registries, archived web content, and automated correlation tools such as Maltego. It emphasized that reconnaissance enables attackers to map infrastructure, identify hosting providers, understand naming conventions, and uncover potential entry points before exploitation occurs. Established security frameworks recognize reconnaissance as a formal stage of adversarial operations because publicly accessible data can significantly expand an organization’s attack surface (Scarfone & Mell, 2007; Weidman, 2014).

Technical Context

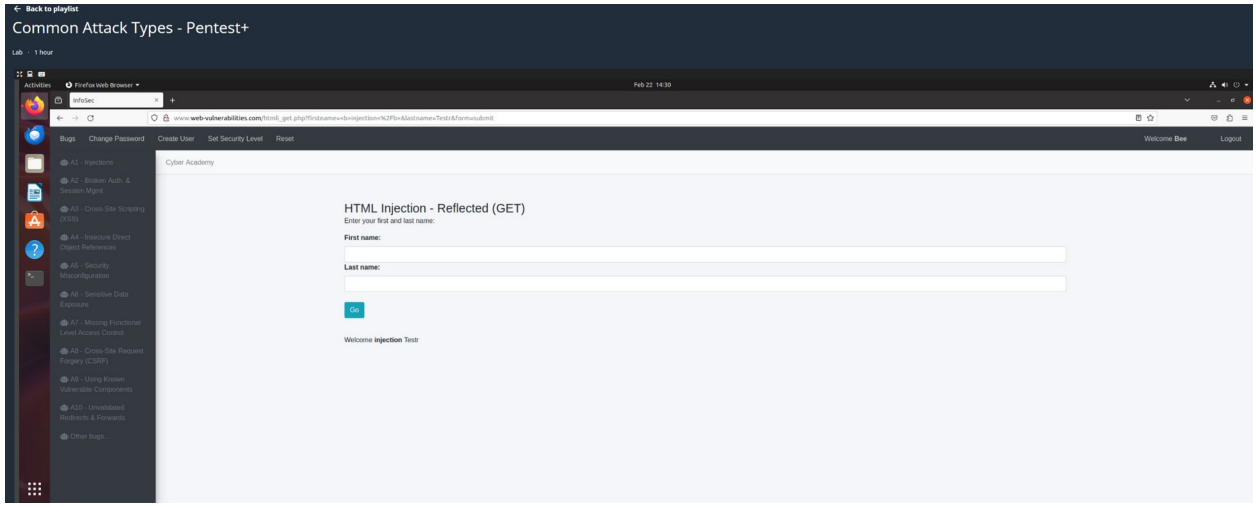
The Common Attack Types lab focused on injection-based vulnerabilities within web applications with a focus on SQL injection, OS command injection, and HTML injection. The focus was on improper input validation and inadequate output encoding, conditions that allow untrusted user-supplied data to be concatenated directly into SQL statements, shell commands, or rendered HTML responses. When input is not

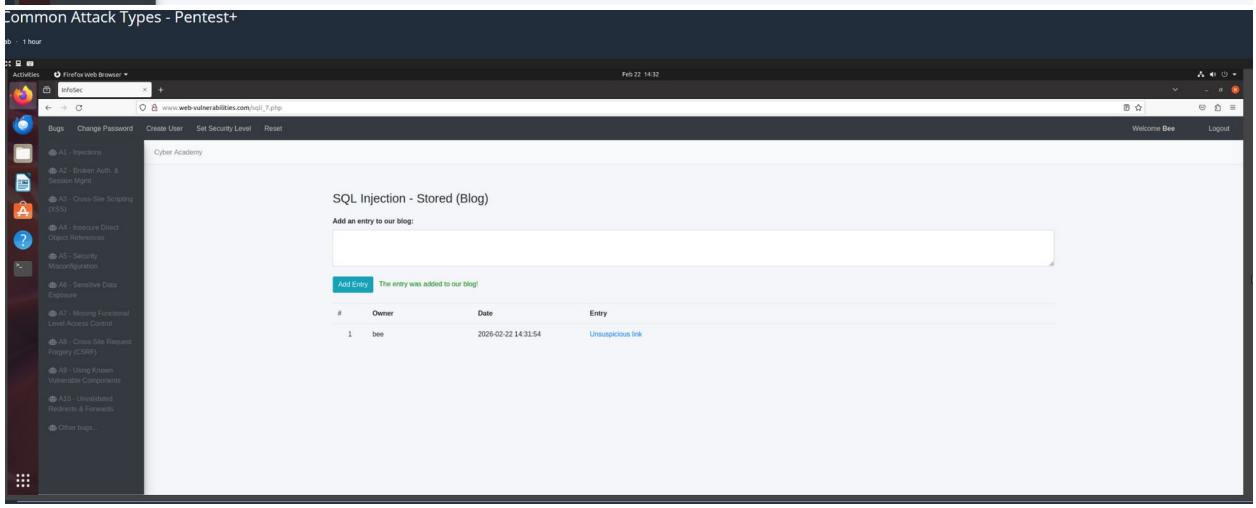
sanitized, attackers can alter query structure, manipulate execution flow, and access backend data stores outside intended authorization boundaries. These flaws undermine core security properties by enabling unauthorized data disclosure, authentication bypass, and, in some cases, remote command execution. Injection vulnerabilities remain among the highest-risk categories in modern web applications due to their direct impact on database integrity and system-level access (OWASP Foundation, 2021).

The lab also reinforced secure development lifecycle considerations by showing both direct and blind exploitation techniques. In blind injection scenarios, side effects such as timing discrepancies or response anomalies are used to confirm successful payload execution even when output is suppressed. This reflects realistic adversarial methods, where attackers refine payloads based on application behavior and error handling patterns. Persistent injection prevalence is strongly correlated with insufficient use of parameterized queries, weak server-side validation controls, and inadequate dynamic and static application security testing (Veracode, 2023). Mitigation strategies include strict input validation schemas, context-aware output encoding, prepared statements, least-privilege database configurations, and integration of automated security testing throughout continuous integration and continuous delivery pipelines.

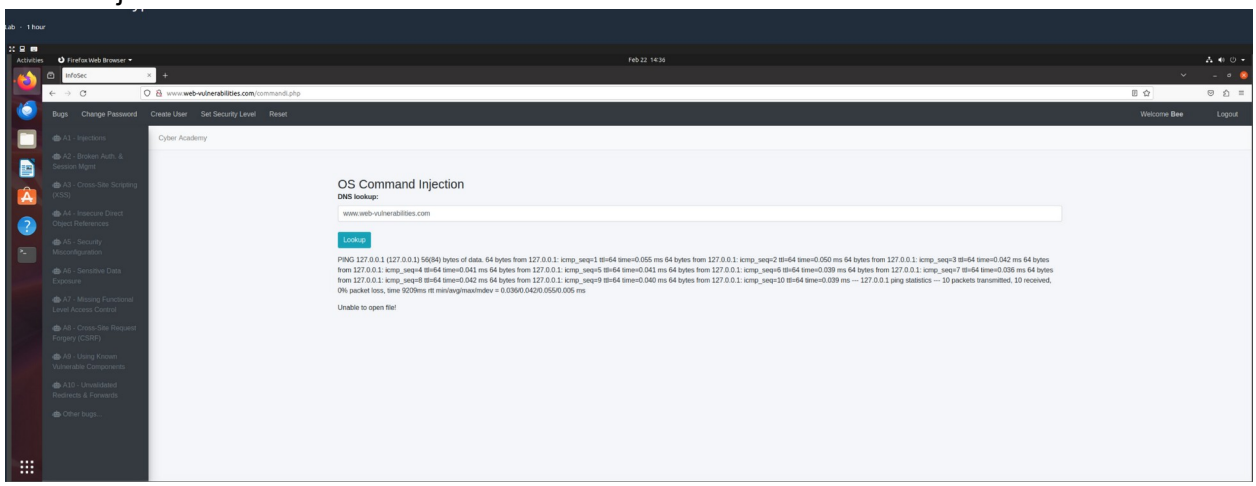
The Recon and Footprinting course covered reconnaissance as a structured intelligence gathering phase before active exploitation. DNS records, WHOIS, and regional internet registry data, IP space attribution, subdomain discovery, and historical web artifact analysis through archived content were some of the things covered. Automated OSINT aggregation platforms demonstrated how disparate datasets can be linked to reveal infrastructure topology, hosting relationships, email addressing conventions, and potential attack vectors. Reconnaissance enables adversaries to construct an accurate external attack surface model before initiating exploitation attempts. Security frameworks formally recognize reconnaissance and enumeration as defined stages within the intrusion lifecycle, as publicly accessible metadata can materially reduce attacker uncertainty and increase exploitation efficiency (Scarfone & Mell, 2007; Weidman, 2014).

Screenshots

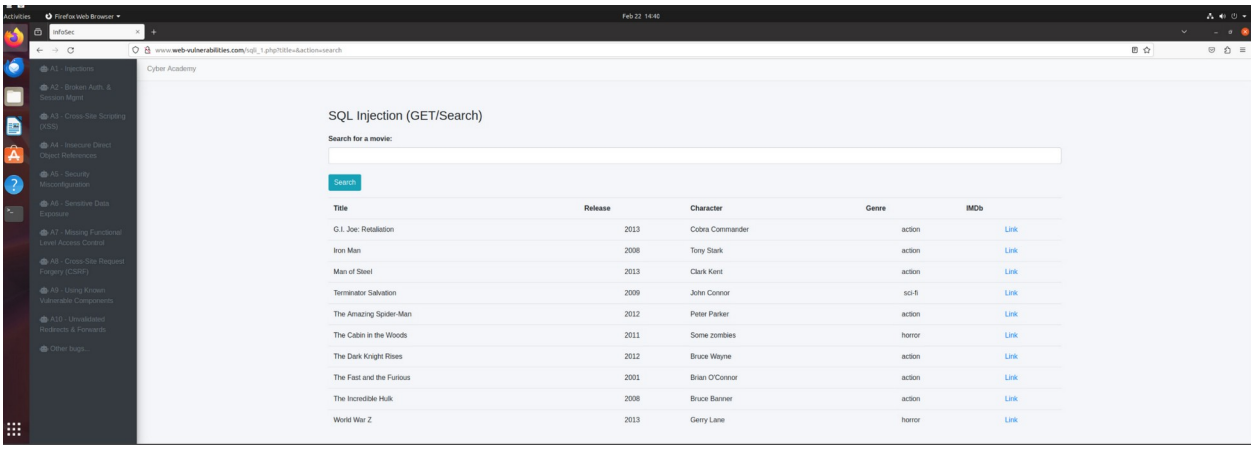




HTML Injection



OS Command Injection



SQL Injection

Common Attack Types - Pentest+
Lab · 1 hour
Delve into some very common attacks and exploits

References

OWASP Foundation. (2021). OWASP Top 10: The ten most critical web application security risks. https://owasp.org/www-project-top-ten/

Scarfone, K., & Mell, P. (2007). Guide to intrusion detection and prevention systems (IDPS) (NIST Special Publication 800-94). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-94

Veracode. (2023). State of software security report. https://www.veracode.com

Weidman, G. (2014). Penetration testing: A hands-on introduction to hacking. No Starch Press.